

PONTIFÍCIA UNIVERSIDADE CATÓLICA DE MINAS GERAIS

CURSO: Sistemas de Informação – EAD

ALUNOS:

Ana Clara Rodrigues de Araújo
Ingrid Rebeca Silva
Isabelle Alves de Lima
Pedro Henrique Barroso Ribeiro dos Santos
Saulo de Tarso Morais Ribeiro
Vitor de Castro Coelho.

INSTRUTOR:

Alexandre Teixeira



PROJETO DA INFRAESTRUTURA DE REDE

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

1. INTRODUÇÃO	4
1.1. Objetivo	4
1.2. Escopo.....	4
2. PRINCÍPIOS DE SEGURANÇA.....	5
2.1. Confidencialidade	5
2.2. Integridade.....	5
2.3. Disponibilidade	5
3. GERENCIAMENTO DE ACESSO	5
3.1. Controle de Acesso.....	6
3.2. Autenticação.....	6
3.3. Autorização	7
4. SEGURANÇA FÍSICA E AMBIENTAL	7
4.1. Proteção de instalações	8
4.2. Controle de acesso físico	8
4.3. Segurança ambiental.....	8
5. SEGURANÇA DE REDES E COMUNICAÇÕES.....	9
5.1. Proteção de redes.....	9
5.2. Monitoramento e detecção de intrusões	9
6. GESTÃO DE INCIDENTES DE SEGURANÇA	10
6.1. Resposta a incidentes.....	10
6.2. Relatórios de incidentes	10
7. CONSCIENTIZAÇÃO E TREINAMENTO EM SEGURANÇA	11
7.1. Programa de conscientização	11
7.2. Treinamento em segurança.....	11
8. AVALIAÇÃO E MELHORIA CONTÍNUA.....	12

8.1. Auditorias de segurança.....	12
8.2. Revisão de políticas e procedimentos.....	12
8.3. Análise de riscos.....	13
8.4. Medição de desempenho	13
9. CONFORMIDADE LEGAL E REGULATÓRIA.....	13
9.1. Conformidade com leis e regulamentações	14
9.2. Gerenciamento de vulnerabilidades e patches.....	14
10. RESPONSABILIDADES	14
10.1. Direção.....	15
10.2. Equipe de segurança da informação.....	15
10.3. Funcionários.....	16

1. Introdução

Uma Política de Segurança da Informação de modelo é um conjunto estruturado de diretrizes, normas e práticas que orienta a proteção e o gerenciamento dos recursos de uma organização, incluindo informações, ativos tecnológicos e infraestrutura de TI. Seu objetivo é estabelecer controles que garantam a integridade, confidencialidade e disponibilidade desses recursos, reduzindo riscos e assegurando a continuidade das operações.

No contexto da organização, esta política é aplicada a uma infraestrutura híbrida composta por servidores em nuvem (cloud), servidores e estações em ambiente local (on-premises) e por uma plataforma central de monitoramento, responsável pela supervisão contínua dos serviços e recursos de TI.

Este documento serve como referência para padronizar comportamentos, processos e controles de segurança, garantindo que todos os usuários e sistemas operem dentro de um nível adequado de proteção da informação e conformidade com boas práticas de segurança.

1.1. Objetivo

Esta Política de Segurança da Informação estabelece diretrizes, regras e controles aplicáveis ao ambiente tecnológico da organização, com o objetivo de proteger os ativos de informação e garantir a operação segura, contínua e controlada da infraestrutura de TI.

Este documento visa assegurar a proteção dos dados e sistemas utilizados no ambiente híbrido da organização, composto por servidores hospedados em nuvem, estações e servidores em ambiente local (on-premises), além da plataforma central de monitoramento, responsável pela supervisão contínua da infraestrutura.

A política tem como finalidade garantir que todos os ativos tecnológicos sejam protegidos contra acessos não autorizados, falhas operacionais, perda de dados, indisponibilidade de serviços e alterações indevidas, assegurando os princípios de confidencialidade, integridade e disponibilidade da informação.

1.2. Escopo

Esta política aplica-se a todos os usuários, colaboradores, administradores de sistema, prestadores de serviço e terceiros que interajam com os ativos de TI da organização, independentemente da localização física ou lógica dos recursos.

O escopo abrange toda a infraestrutura tecnológica da organização, incluindo:

- Servidores hospedados em ambiente de nuvem (cloud);
- Servidores e estações de trabalho localizados no ambiente interno (on-premises);
- Dispositivos de rede e equipamentos de comunicação;
- Ferramenta de monitoramento e seus agentes distribuídos;
- Sistemas, serviços, aplicações e bases de dados utilizados para suporte às operações;
- Ambientes de comunicação entre cloud e rede local.

Esta política se aplica a todas as formas de acesso, processamento, armazenamento e transmissão de informações, independentemente do meio utilizado.

2. Princípios de Segurança

Os princípios de segurança da informação da organização são aplicados a toda a infraestrutura tecnológica, incluindo ambientes em nuvem, ambiente local, bem como a plataforma central de monitoramento, responsável pela observação contínua dos ativos de TI.

Esses princípios orientam a configuração, operação, monitoramento e manutenção de todos os sistemas, garantindo proteção adequada das informações e dos serviços críticos.

2.1. Confidencialidade

A confidencialidade deve ser garantida em todos os ambientes da organização, assegurando que informações, credenciais, configurações de sistemas e dados operacionais sejam acessados exclusivamente por usuários autorizados.

No ambiente em nuvem, o acesso aos servidores deve ser restrito por autenticação segura (ex.: SSH com chaves), com controle rigoroso de permissões administrativas.

No ambiente local, o acesso deve ser controlado por autenticação integrada ao domínio e políticas de grupo (GPO), garantindo segregação de funções.

A plataforma de monitoramento deve ter acesso restrito apenas à equipe responsável pela infraestrutura, sendo proibido o compartilhamento de credenciais ou acesso não autorizado aos painéis de monitoramento e dados de performance.

2.2. Integridade

A integridade deve ser assegurada em todos os sistemas, garantindo que dados, configurações e registros de monitoramento não sejam alterados de forma indevida ou não autorizada.

No ambiente híbrido, alterações em servidores devem ser registradas por meio de logs centralizados e auditáveis.

A plataforma de monitoramento deve manter a integridade dos dados coletados, incluindo métricas de desempenho, disponibilidade de serviços, logs de eventos e alertas gerados automaticamente, sem possibilidade de manipulação por usuários não autorizados.

Mudanças em configurações críticas de rede, servidores ou agentes de monitoramento devem ser documentadas e rastreáveis.

2.3. Disponibilidade

A disponibilidade dos serviços e da infraestrutura deve ser garantida de forma contínua, assegurando a operação dos sistemas essenciais da organização.

O ambiente híbrido deve ser monitorado continuamente por meio da plataforma de monitoramento, que será responsável por identificar falhas em servidores na nuvem, servidores locais, dispositivos de rede e serviços críticos.

Alertas automáticos devem ser configurados para notificar a equipe responsável em caso de indisponibilidade, degradação de performance ou falhas em serviços essenciais.

Devem ser adotadas práticas como redundância de serviços, backups regulares, monitoramento ativo e procedimentos de recuperação (disaster recovery), garantindo a continuidade das operações tanto no ambiente cloud quanto no ambiente local.

3. Gerenciamento de Acesso

O gerenciamento de acesso da organização define as diretrizes para controle, autenticação e autorização de usuários em todos os ambientes tecnológicos, incluindo servidores em nuvem, servidores e estações no ambiente local e a plataforma central de monitoramento.

O objetivo é garantir que somente usuários devidamente identificados e autorizados possam acessar sistemas, dados e recursos da infraestrutura, de acordo com suas funções e responsabilidades.

3.1. Controle de Acesso

O controle de acesso tem como objetivo garantir que apenas usuários devidamente autorizados possam acessar sistemas, informações e recursos da organização, assegurando a proteção do ambiente híbrido composto por infraestrutura em nuvem, ambiente local e a plataforma central de monitoramento.

A organização deve adotar controles de acesso baseados no princípio do menor privilégio, garantindo que cada usuário possua apenas as permissões estritamente necessárias para execução de suas atividades.

A implementação do controle de acesso deve ser realizada por meio de mecanismos de autenticação individual, segregação de funções e rastreabilidade de ações, abrangendo todos os ambientes tecnológicos da organização.

Medidas implementadas:

- Aplicação do princípio do menor privilégio em todos os sistemas e ambientes;
- Proibição do uso de contas compartilhadas ou genéricas;
- Controle formal de concessão, alteração e revogação de acessos mediante solicitação e aprovação;
- Revisão periódica de permissões de usuários e perfis de acesso;
- Registro e auditoria de acessos e atividades realizadas nos sistemas;
- Restrição de acessos administrativos apenas a usuários autorizados e devidamente identificados;
- Segregação de funções entre usuários operacionais e administrativos.

3.2. Autenticação

Todos os acessos aos sistemas da organização devem ser submetidos a mecanismos de autenticação seguros, com o objetivo de garantir a verificação da identidade do usuário antes da concessão de qualquer tipo de acesso aos recursos tecnológicos.

A autenticação deve ser obrigatoriamente individual, intransferível e rastreável, sendo vedado o uso de credenciais compartilhadas ou genéricas em qualquer ambiente da infraestrutura híbrida (nuvem, ambiente local e sistemas de monitoramento).

A organização deve adotar mecanismos de autenticação compatíveis com o nível de criticidade dos sistemas, incluindo o uso de métodos criptográficos, integração com serviços de diretório e políticas de segurança reforçadas.

Medidas implementadas:

- Obrigatoriedade de autenticação individual para todos os usuários e sistemas;
- Utilização de mecanismos seguros de autenticação, incluindo autenticação por chaves criptográficas em acessos remotos;
- Integração com diretório corporativo para centralização e controle de identidades;
- Aplicação de políticas de senha forte, incluindo complexidade mínima, expiração periódica e bloqueio após tentativas inválidas;
- Implementação de autenticação multifator (MFA) para perfis administrativos e acessos a sistemas críticos;
- Registro de tentativas de autenticação bem-sucedidas e malsucedidas para fins de auditoria e detecção de atividades suspeitas.

3.3. Autorização

A autorização de acesso deve ser baseada em perfis de usuário previamente definidos, assegurando que cada usuário possua permissões compatíveis com suas funções, responsabilidades e necessidades operacionais dentro da organização.

A concessão de permissões deve seguir critérios formais de segregação de funções, garantindo que acessos administrativos, operacionais e de visualização sejam devidamente separados em todos os sistemas da infraestrutura híbrida (ambiente em nuvem, ambiente local e plataforma de monitoramento).

A organização deve garantir que a autorização de acesso seja aplicada de forma controlada, rastreável e revisada periodicamente, evitando concessões excessivas ou incompatíveis com a função do usuário.

Medidas implementadas:

- Definição de perfis de acesso baseados em função e necessidade operacional;
- Aplicação do princípio da segregação de funções entre perfis administrativos, operacionais e de visualização;
- Concessão de acessos baseada em aprovação formal do responsável técnico ou gestor da área;

- Restrição de permissões elevadas apenas a usuários autorizados e devidamente justificados;
- Revisão periódica dos acessos concedidos para garantir aderência às funções atuais dos usuários;
- Registro de todas as solicitações, aprovações e alterações de permissões para fins de auditoria e rastreabilidade.

4. Segurança Física e Ambiental

A organização deve implementar controles físicos e ambientais obrigatórios para garantir a proteção da infraestrutura de TI, assegurando a continuidade dos serviços, a integridade dos equipamentos e o funcionamento adequado dos sistemas em ambiente local (on-premises) e sua integração com serviços em nuvem, incluindo a plataforma de monitoramento.

4.1. Proteção de instalações

As áreas que hospedam recursos de TI da organização devem ser classificadas como áreas restritas e protegidas por controles físicos obrigatórios.

Devem ser implementadas as seguintes medidas mínimas:

- Servidores on-premises e equipamentos de rede devem estar localizados em sala técnica exclusiva ou área controlada;
- Acesso físico às salas técnicas deve ser limitado e sinalizado como área restrita;
- Equipamentos devem ser instalados em racks organizados, com identificação de ativos e controle de inventário;
- Cabos de rede e energia devem ser organizados e protegidos para evitar desconexões acidentais ou intervenções não autorizadas;
- A infraestrutura que suporta o acesso aos serviços em nuvem deve estar protegida contra interrupções de energia e falhas de rede local;
- O servidor ou ambiente responsável pela plataforma de monitoramento deve ser considerado componente crítico da infraestrutura e mantido em ambiente protegido.

4.2. Controle de acesso físico

O acesso às áreas críticas da infraestrutura de TI deve ser rigidamente controlado para impedir acessos não autorizados.

Devem ser adotados os seguintes controles obrigatórios:

- Acesso às salas de servidores somente para equipe de TI autorizada;
- Registro de entrada e saída de pessoas em áreas restritas (manual ou sistema eletrônico);
- Uso de credenciais individuais, chaves físicas ou cartões de acesso para liberação de entrada;
- Proibição de acesso não acompanhado para visitantes, fornecedores ou terceiros;
- Revisão periódica da lista de pessoas autorizadas a acessar áreas críticas;
- Qualquer acesso emergencial deve ser registrado e justificado posteriormente.

4.3. Segurança ambiental

A organização deve implementar controles para garantir a continuidade operacional da infraestrutura de TI, prevenindo impactos causados por falhas ambientais ou interrupções externas.

Devem ser aplicadas, no mínimo, as seguintes medidas:

- Uso obrigatório de nobreaks (UPS) para servidores locais on-premises, switches e equipamentos de rede;
- Proteção contra surtos elétricos em todos os equipamentos críticos;
- Monitoramento de energia elétrica e alertas de falhas por meio da plataforma de monitoramento;
- Sistema de climatização adequado para manter temperatura operacional dos equipamentos;
- Procedimentos de backup automático dos servidores locais e validação periódica de restauração;
- Dependência da infraestrutura cloud deve ser suportada por serviços com alta disponibilidade do provedor;
- A plataforma de monitoramento deve ser configurada com redundância ou backup de configuração para evitar perda de monitoramento em caso de falha.

5. Segurança de Redes e Comunicações

A organização deve implementar e manter controles de segurança para proteção das redes e comunicações de dados, considerando sua arquitetura híbrida composta por ambiente local, ambiente em nuvem e a plataforma central de monitoramento.

Esses controles têm como objetivo garantir a proteção contra acessos não autorizados, interceptação de dados, ataques internos e externos, bem como assegurar a integridade e disponibilidade das comunicações entre os ambientes.

5.1. Proteção de redes

A rede da organização deve ser protegida por mecanismos de segurança que garantam o isolamento lógico, controle de tráfego e proteção contra acessos indevidos.

Devem ser implementados, no mínimo, os seguintes controles obrigatórios:

- Segmentação da rede interna por meio de VLANs ou separação lógica entre ambientes administrativos, servidores e estações de trabalho;
- Implementação de firewall entre a rede local e a internet, com regras restritivas de entrada e saída de tráfego;
- Comunicação com servidores em nuvem deve ocorrer por meio de canais seguros (ex.: VPN ou SSH com criptografia);
- Restrição de portas e serviços expostos, permitindo apenas os estritamente necessários para operação;
- Uso de regras de acesso para limitar comunicação entre agentes de monitoramento e o servidor central de monitoramento;

- Proibição de acessos diretos não autenticados entre ambientes local e cloud;
- Revisão periódica das regras de firewall e acessos de rede.

5.2. Monitoramento e detecção de intrusões

A organização deve implementar mecanismos contínuos de monitoramento da rede e detecção de eventos suspeitos, com o objetivo de identificar, registrar e responder a incidentes de segurança em tempo hábil.

Devem ser adotadas as seguintes medidas obrigatórias:

- Utilização da plataforma de monitoramento como ferramenta central de monitoramento da infraestrutura, incluindo servidores em nuvem e local, dispositivos de rede e serviços críticos;
- Configuração de alertas automáticos para eventos como indisponibilidade de serviços, alta utilização de recursos, falhas de comunicação e tentativas de acesso não autorizado;
- Registro centralizado de logs de sistemas e eventos de segurança para auditoria;
- Implementação de níveis de severidade para incidentes detectados (crítico, alto, médio e baixo);
- Monitoramento contínuo da comunicação entre agentes de monitoramento e o servidor central, garantindo detecção de falhas de monitoramento;
- Adoção de procedimentos de resposta a incidentes com acionamento automático ou manual da equipe responsável em caso de alerta crítico;
- Análise periódica dos logs e eventos de segurança para identificação de padrões suspeitos ou tentativas de intrusão.

6. Gestão de Incidentes de Segurança

A organização deve estabelecer e manter um processo formal de gestão de incidentes de segurança da informação, com o objetivo de identificar, registrar, analisar, responder e mitigar eventos que possam comprometer a confidencialidade, integridade ou disponibilidade dos ativos de informação.

Esse processo aplica-se a todo o ambiente tecnológico da organização, incluindo servidores em nuvem, servidores e estações em ambiente local (on-premises), dispositivos de rede e a plataforma de monitoramento.

6.1. Resposta a incidentes

A organização deve possuir um processo estruturado de resposta a incidentes de segurança, com foco na redução de impacto e restauração rápida da operação dos serviços afetados.

Devem ser aplicadas as seguintes diretrizes obrigatórias:

- Todos os incidentes detectados pela plataforma de monitoramento (ex.: indisponibilidade de servidor, falha de serviço, alta utilização de recursos ou perda de conectividade) devem gerar alerta automático para a equipe responsável;
- Incidentes devem ser classificados por nível de severidade (crítico, alto, médio e baixo) com base no impacto operacional;

- A equipe de TI deve iniciar a análise do incidente imediatamente após sua detecção ou notificação;
- Para incidentes críticos, deve ser acionado procedimento de resposta imediata, incluindo isolamento do sistema afetado quando necessário;
- Sistemas em nuvem e locais devem seguir procedimentos específicos de contenção conforme o tipo de falha ou ataque identificado;
- Toda ação corretiva ou mitigadora deve ser registrada para fins de auditoria e rastreabilidade;
- Após resolução, deve ser realizada análise de causa raiz para evitar recorrência do incidente.

6.2. Relatórios de incidentes

Todos os incidentes de segurança devem ser reportados, registrados e documentados de forma obrigatória.

Devem ser aplicadas as seguintes regras:

- Qualquer colaborador, prestador de serviço ou administrador que identificar um incidente deve reportá-lo imediatamente à equipe responsável por segurança da informação ou infraestrutura de TI;
- O registro do incidente deve conter, no mínimo: data, hora, descrição do evento, sistemas afetados, impacto observado e ações tomadas;
- A plataforma de monitoramento deve ser utilizada como fonte oficial de registro técnico para eventos relacionados à infraestrutura;
- Todos os incidentes devem ser armazenados em base centralizada para análise posterior e auditoria;
- Relatórios periódicos de incidentes devem ser gerados para identificação de padrões de falhas e melhoria contínua da infraestrutura;
- A não comunicação de incidentes conhecidos poderá ser tratada como falha de conformidade com esta política.

7. Conscientização e Treinamento em Segurança

A organização deve implementar um programa contínuo de conscientização e treinamento em segurança da informação, aplicável a todos os colaboradores, prestadores de serviço e administradores de sistemas que tenham acesso ao ambiente tecnológico.

Esse programa tem como objetivo reduzir riscos operacionais e humanos, garantindo que todos os usuários compreendam suas responsabilidades na proteção dos ativos de informação da organização, incluindo ambientes em nuvem, ambiente local e a plataforma de monitoramento.

7.1. Programa de conscientização

A organização deve manter um programa contínuo de conscientização em segurança da informação, com foco na prevenção de incidentes e no uso seguro dos recursos tecnológicos.

Devem ser aplicadas as seguintes diretrizes obrigatórias:

- Todos os colaboradores com acesso aos sistemas da organização devem participar de ações periódicas de conscientização em segurança da informação;
- O programa deve incluir orientações sobre uso seguro de credenciais, prevenção de phishing, boas práticas de acesso remoto e proteção de dados;
- Deve haver comunicação recorrente sobre riscos de segurança aplicáveis ao ambiente híbrido, incluindo acesso a servidores em nuvem e sistemas locais;
- Usuários com acesso à infraestrutura ou à plataforma de monitoramento devem receber orientações específicas sobre boas práticas de uso e responsabilidade operacional;
- Falhas recorrentes de comportamento seguro podem resultar em restrição temporária de acesso aos sistemas.

7.2. Treinamento em segurança

A organização deve fornecer treinamentos formais e periódicos em segurança da informação, de acordo com o perfil de acesso e responsabilidade de cada usuário.

Devem ser aplicadas as seguintes regras obrigatórias:

- Novos colaboradores devem receber treinamento obrigatório de segurança da informação antes de obter acesso aos sistemas;
- Administradores de sistemas devem receber treinamento técnico específico sobre segurança da infraestrutura e gestão de acessos;
- Treinamentos devem ser realizados periodicamente para atualização sobre novas ameaças, vulnerabilidades e boas práticas de segurança;
- O conteúdo dos treinamentos deve incluir práticas de segurança em ambientes híbridos, incluindo uso seguro de SSH, autenticação em sistemas locais e operação segura de ferramentas de monitoramento;
- A participação nos treinamentos deve ser registrada e pode ser utilizada como critério de conformidade de segurança interna;
- A não participação em treinamentos obrigatórios pode resultar em restrição de acesso a sistemas críticos.

8. Avaliação e Melhoria Contínua

A organização deve estabelecer um processo contínuo de avaliação, auditoria e melhoria das práticas de segurança da informação, com o objetivo de garantir a eficácia das medidas implementadas e a adaptação constante a mudanças tecnológicas, operacionais e de ameaças.

Esse processo aplica-se a toda a infraestrutura tecnológica da organização, incluindo ambientes em nuvem, ambiente local, dispositivos de rede e a plataforma de monitoramento.

8.1. Auditorias de segurança

A organização deve realizar auditorias periódicas de segurança da informação para verificar a conformidade com esta política e identificar vulnerabilidades, falhas de configuração ou riscos operacionais.

Devem ser aplicadas as seguintes diretrizes obrigatórias:

- Auditorias internas devem ser realizadas periodicamente no ambiente on-premises, infraestrutura em nuvem e na plataforma de monitoramento;
- Devem ser verificados controles de acesso, configurações de rede, permissões de usuários e registros de logs;
- O histórico de eventos e alertas gerados pela plataforma de monitoramento deve ser utilizado como base para análise de conformidade e detecção de falhas;
- Não conformidades identificadas devem ser registradas e tratadas com plano de ação corretivo;
- Resultados das auditorias devem ser reportados à equipe responsável pela infraestrutura de TI.

8.2. Revisão de políticas e procedimentos

As políticas e procedimentos de segurança da informação devem ser revisados periodicamente para garantir sua atualização e eficácia frente às mudanças tecnológicas e operacionais.

Devem ser aplicadas as seguintes regras:

- A revisão desta política deve ocorrer em intervalos regulares ou sempre que houver mudanças significativas na infraestrutura ou nos riscos de segurança;
- Alterações em ambientes críticos, como migração de serviços para nuvem ou mudanças na arquitetura de rede, devem acionar revisão imediata da política;
- Lições aprendidas de incidentes de segurança registrados (incluindo eventos detectados pela plataforma de monitoramento) devem ser incorporadas às atualizações da política;
- Todas as alterações devem ser documentadas e comunicadas às partes envolvidas.

8.3. Análise de riscos

A organização deve realizar análises periódicas de riscos para identificar, avaliar e tratar ameaças que possam impactar seus ativos de informação.

Devem ser aplicadas as seguintes diretrizes obrigatórias:

- A análise de riscos deve abranger ambientes cloud, locais e infraestrutura de rede;
- Devem ser considerados riscos como indisponibilidade de serviços, falhas de segurança, ataques externos, falhas de configuração e perda de dados;
- A plataforma de monitoramento deve ser utilizada como fonte de dados para identificação de comportamentos anômalos e riscos operacionais;
- Cada risco identificado deve ser classificado quanto à probabilidade e impacto;
- Devem ser implementadas medidas de mitigação proporcionais ao nível de risco identificado.

8.4. Medição de desempenho

A organização deve estabelecer métricas e indicadores de desempenho (KPIs) para avaliar a eficácia das medidas de segurança da informação e da infraestrutura de TI.

Devem ser aplicados, no mínimo, os seguintes indicadores:

- Disponibilidade dos servidores cloud e on-premises;
- Tempo médio de detecção de incidentes via plataforma de monitoramento;
- Tempo médio de resposta a incidentes de segurança;

- Número de incidentes registrados por período;
- Taxa de falhas de autenticação ou acessos não autorizados;
- Efetividade dos alertas e monitoramento da infraestrutura.

Os resultados desses indicadores devem ser analisados periodicamente para apoiar decisões de melhoria contínua da segurança da informação.

9. Conformidade Legal e Regulatória

A organização deve garantir que todas as suas práticas de segurança da informação estejam em conformidade com leis, regulamentações, normas aplicáveis e boas práticas de mercado, abrangendo todo o ambiente tecnológico, incluindo servidores em nuvem, servidores e estações em ambiente local (on-premises), dispositivos de rede e a plataforma de monitoramento.

9.1. Conformidade com leis e regulamentações

A organização deve assegurar que suas políticas, processos e controles de segurança da informação estejam em conformidade com a legislação vigente e requisitos regulatórios aplicáveis à proteção de dados e segurança da informação.

Devem ser aplicadas as seguintes diretrizes obrigatórias:

- Todos os dados pessoais e sensíveis tratados pela organização devem seguir princípios de proteção, minimização de acesso e uso controlado;
- A organização deve adotar medidas de segurança compatíveis com leis de proteção de dados aplicáveis (ex.: privacidade, confidencialidade e retenção de dados);
- O acesso a informações pessoais ou críticas deve ser restrito por perfis de autorização e registrado para fins de auditoria;
- Logs de acesso e eventos de segurança (incluindo os gerados pela plataforma de monitoramento) devem ser mantidos para suporte a auditorias internas e externas;
- Em caso de incidentes de segurança envolvendo dados sensíveis, devem ser seguidos procedimentos formais de resposta e notificação conforme exigido por regulamentações aplicáveis;
- A infraestrutura híbrida (cloud e local) deve garantir que o tratamento de dados não viole requisitos legais de armazenamento, acesso e transferência de informações.

9.2. Gerenciamento de vulnerabilidades e patches

A organização deve implementar um processo contínuo de identificação, análise, priorização e correção de vulnerabilidades de segurança em todos os sistemas operacionais, aplicações e componentes da infraestrutura híbrida.

Devem ser aplicadas as seguintes diretrizes obrigatórias:

- Todos os sistemas devem ser mantidos atualizados com patches de segurança conforme criticidade da vulnerabilidade;
- Vulnerabilidades devem ser priorizadas com base em impacto operacional e risco à confidencialidade, integridade e disponibilidade;

- O processo de gestão de vulnerabilidades deve considerar boas práticas reconhecidas internacionalmente, incluindo o **OWASP Top 10** para aplicações web e sistemas expostos.

Entre as principais classes de vulnerabilidades que devem ser monitoradas e mitigadas, destacam-se:

- **Broken Access Control (Controle de Acesso Quebrado):** falhas que permitem que usuários acessem recursos ou dados sem autorização adequada, especialmente críticas em sistemas administrativos e ferramentas como painéis de monitoramento.
- **Injection (Injeção de Comandos ou SQL):** vulnerabilidades que permitem a execução de comandos maliciosos em bancos de dados ou sistemas operacionais, podendo comprometer servidores em nuvem ou aplicações web internas.
- **Security Misconfiguration (Má Configuração de Segurança):** falhas decorrentes de configurações incorretas em servidores, firewalls, permissões de sistema ou serviços expostos, comuns em ambientes híbridos com múltiplas camadas (cloud e on-premises).

Outras vulnerabilidades relevantes devem ser avaliadas conforme evolução do OWASP Top 10 e riscos identificados na infraestrutura.

Após a aplicação de correções (patches), deve ser realizada validação técnica para garantir a estabilidade dos sistemas e a mitigação efetiva da vulnerabilidade sem impacto na operação.

10. Responsabilidades

A governança da segurança da informação da organização é estruturada com base na definição clara de responsabilidades, assegurando que todos os níveis organizacionais contribuam para a proteção dos ativos de informação, incluindo o ambiente híbrido composto por servidores em nuvem, servidores e estações em ambiente local (on-premises) e a plataforma de monitoramento.

10.1. Direção

A direção da organização é responsável por estabelecer, aprovar e patrocinar a Política de Segurança da Informação, garantindo que os recursos necessários sejam disponibilizados para sua implementação e manutenção.

Compete à direção:

- Aprovar diretrizes e revisões da política de segurança da informação;
- Garantir recursos financeiros, humanos e tecnológicos para a segurança da infraestrutura híbrida;
- Apoiar iniciativas de segurança da informação e continuidade operacional;
- Garantir alinhamento da segurança com os objetivos estratégicos da organização;
- Promover uma cultura organizacional orientada à segurança da informação.

10.2. Equipe de segurança da informação

A equipe responsável pela segurança da informação e infraestrutura de TI é encarregada da implementação, operação e monitoramento dos controles de segurança definidos nesta política.

Compete à equipe:

- Implementar e manter controles de segurança em ambientes cloud e on-premises;
- Configurar, operar e monitorar continuamente a plataforma de monitoramento como ferramenta central de observabilidade da infraestrutura;
- Gerenciar alertas, eventos e incidentes de segurança e infraestrutura;
- Aplicar políticas de controle de acesso, autenticação e autorização;
- Realizar análise de vulnerabilidades, aplicação de patches e mitigação de riscos;
- Garantir a integridade, disponibilidade e confiabilidade dos sistemas monitorados;
- Investigar incidentes de segurança e propor melhorias contínuas.

10.3. Funcionários

Todos os usuários da organização, incluindo colaboradores, prestadores de serviço e terceiros autorizados, são responsáveis pelo cumprimento das diretrizes desta política.

Compete aos usuários:

- Utilizar os recursos de TI de forma segura e responsável;
- Manter confidencialidade de credenciais de acesso, sendo proibido o compartilhamento de senhas;
- Seguir as regras de acesso definidas para sistemas em nuvem e ferramentas corporativas;
- Reportar imediatamente qualquer incidente de segurança, comportamento suspeito ou falha identificada;
- Participar de treinamentos e programas de conscientização em segurança da informação;
- Cumprir as orientações de uso seguro dos sistemas, incluindo a plataforma de monitoramento e gestão da infraestrutura.

11. Conclusão

Esta Política de Segurança da Informação estabelece um conjunto estruturado de diretrizes, controles e responsabilidades aplicáveis a todo o ambiente tecnológico da organização, incluindo a infraestrutura híbrida composta por servidores em nuvem, servidores em ambiente local (on-premises) e a plataforma central de monitoramento.

O objetivo desta política é assegurar a proteção contínua dos ativos de informação da organização, garantindo a confidencialidade, integridade e disponibilidade dos dados, sistemas e serviços críticos, por meio da implementação de controles técnicos, administrativos e operacionais.

A adoção desta política contribui para a redução de riscos de segurança, a melhoria da governança de TI, a detecção e resposta eficaz a incidentes, e a promoção de uma cultura organizacional orientada à segurança da informação e à continuidade dos serviços.